Corso di Cybersecurity – Epicode

Report dell'Esercitazione

Analisi di una cattura di rete e identificazione degli IOC

Riconoscimento di una scansione Nmap e verifica sperimentale in laboratorio

A cura di:

Nicola Madonna

Epicode

7 agosto 2026

Indice

1 Riassunto 2
2 Obiettivi 2
3 Configurazione del Laboratorio 3
4 Analisi dei Dati Raccolti 4
4.1 Analisi della cattura 4
4.2 Ipotesi sul vettore di attacco 8
4.3 Verifica sperimentale in laboratorio 8
4.4 Contromisure 13
5 Conclusioni 14

1 Riassunto

Questo report analizza una cattura di traffico di rete con l'obiettivo di individuare gli Indicatori di Compromissione (IOC), formulare un'ipotesi sul tipo di attacco e proporre contromisure. Quasi tutto il traffico avviene tra due host, `192.168.200.100` e `192.168.200.150`: il primo invia 1.026 richieste di connessione (SYN) verso le porte da 1 a 1024 del secondo, e 1.024 di queste partono in circa 105 millisecondi. È la firma di una **scansione di porte**, che individua 12 servizi aperti su un bersaglio riconoscibile come la macchina vulnerabile **Metasploitable2**.

Dai dettagli dei pacchetti è stato possibile risalire anche al tipo di scansione, una **TCP Connect scan** di Nmap (`-sT`), e ricostruire il comando probabile. L'ipotesi è stata verificata riproducendo la scansione in un laboratorio isolato con gli stessi indirizzi IP: il traffico ottenuto con `-sT` coincide con quello originale, mentre quello di una SYN scan (`-sS`) è chiaramente diverso.

2 Obiettivi

- Individuare nella cattura gli IOC che indicano un'attività malevola in corso.
- Formulare un'ipotesi sul vettore di attacco a partire dagli IOC.
- Proporre contromisure per ridurre l'impatto dell'attacco e prevenirne di simili.
- Ricostruire lo strumento e il comando usati e verificare l'ipotesi riproducendo il traffico in laboratorio.

3 Configurazione del Laboratorio

La cattura è stata analizzata con **Wireshark** su una macchina virtuale Kali Linux in VirtualBox. Per la verifica sperimentale è stata aggiunta una seconda macchina virtuale, **Metasploitable2** (kernel `2.6.24-16-server`, hostname `metasploitable`), collegata alla Kali solo tramite una rete interna di VirtualBox, non raggiungibile da Internet né dalla rete fisica. Alle due macchine sono stati assegnati gli stessi indirizzi della cattura originale, `192.168.200.100` alla Kali e `192.168.200.150` a Metasploitable2, per rendere il confronto diretto.

4 Analisi dei Dati Raccolti

4.1 Analisi della cattura

4.1.1 Panoramica del traffico

La cattura contiene 2.083 pacchetti raccolti in circa 37 secondi. Dalla finestra *Statistics* → *Conversations*, scheda IPv4 (Fig. 1), emerge subito un dato: 2.078 pacchetti appartengono a un'unica conversazione tra `192.168.200.100` e `192.168.200.150`, con un rapporto quasi 1:1 tra le due direzioni (1.052 e 1.026 pacchetti).

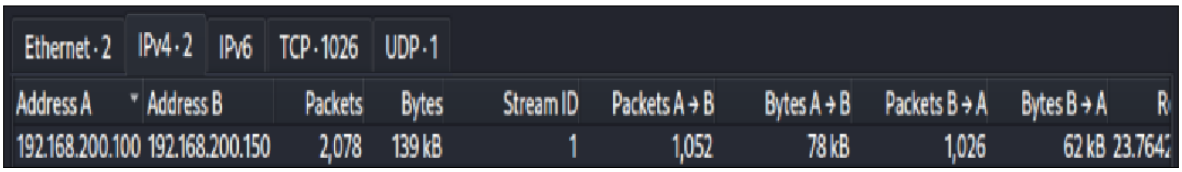


Figura 1: Conversazioni IPv4 della cattura: quasi tutto il traffico è tra 192.168.200.100 e 192.168.200.150.

L'unica altra conversazione è un pacchetto broadcast UDP sulla porta 138 (NetBIOS, servizio Browser) inviato da `192.168.200.150` a `192.168.200.255`, con cui l'host si annuncia con il nome **METASPLOITABLE**: un primo indizio sull'identità del bersaglio.

4.1.2 IOC principale: una scansione di porte

Il filtro `tcp.flags.syn==1 && tcp.flags.ack==0` isola le richieste di apertura di connessione: sono **1.026 pacchetti SYN**, tutti da `192.168.200.100` verso `192.168.200.150` (Fig. 2). Le loro caratteristiche sono:

- le porte di destinazione coprono l'intervallo da 1 a 1024, ciascuna contattata una sola volta, tranne la 80 e la 443, toccate due volte per via di un primo tentativo isolato;
- le porte non vengono contattate in ordine, ma in una sequenza apparentemente casuale;
- la porta di origine cambia a ogni pacchetto;
- le porte chiuse, la grande maggioranza, rispondono subito con un RST;
- sulle porte aperte il client completa l'handshake e poi chiude subito la connessione (dettagli nel §4.2).

Molte richieste verso porte diverse, in rapidissima successione e chiuse appena determinato lo stato della porta: è la firma di una **scansione di porte TCP**, tecnica di ricognizione classificata in MITRE ATT&CK come **T1046 – Network Service Discovery**.

Anche la velocità conferma l'ipotesi. Dai timestamp, i 1.024 SYN della scansione vera e propria sono inviati tra il secondo 36,774 e il secondo 36,879 della cattura: circa **105 millisecondi**, cioè oltre 9.500 pacchetti al secondo. Nessun utente e nessuna applicazione normale genera traffico simile; è invece tipico di uno strumento automatico con temporizzazione aggressiva. Il grafico I/O (Fig. 3) mostra un unico picco isolato di oltre 2.000 pacchetti al secondo proprio in quel punto.



No.	Time	Source	Destination	Protocol	Length	Info
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PER
3	23.764287789	192.168.200.100	192.168.200.150	TCP	74	33876 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
12	36.774143445	192.168.200.100	192.168.200.150	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PER
13	36.774218116	192.168.200.100	192.168.200.150	TCP	74	56120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
15	36.774366305	192.168.200.100	192.168.200.150	TCP	74	58636 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
16	36.774405627	192.168.200.100	192.168.200.150	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PER
29	36.775337800	192.168.200.100	192.168.200.150	TCP	74	59174 → 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
30	36.775386694	192.168.200.100	192.168.200.150	TCP	74	55656 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PER
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	53062 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PER
42	36.776179338	192.168.200.100	192.168.200.150	TCP	74	50684 → 199 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
43	36.776233880	192.168.200.100	192.168.200.150	TCP	74	54220 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE
44	36.776330610	192.168.200.100	192.168.200.150	TCP	74	34648 → 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PE

Figura 2: Pacchetti SYN da 192.168.200.100 verso 192.168.200.150: le porte di destinazione non sono in ordine.

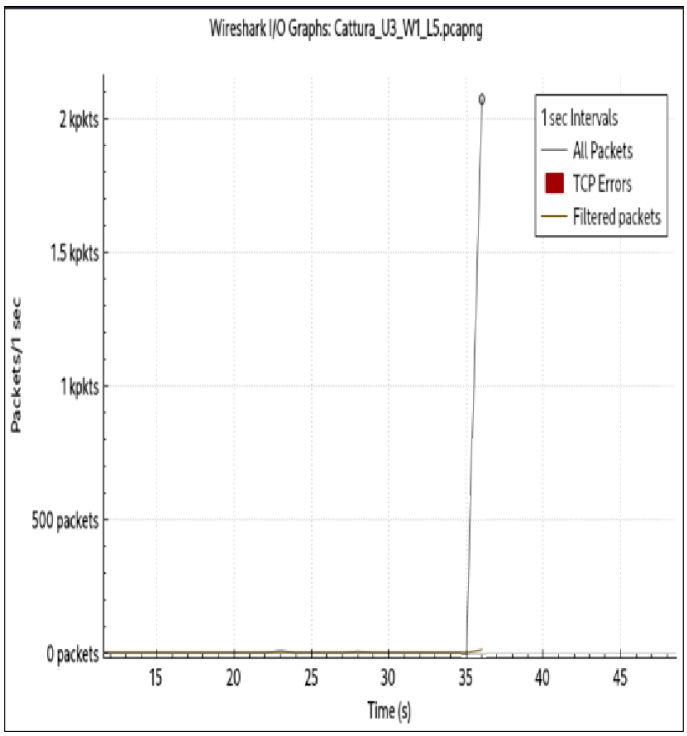


Figura 3: Grafico I/O della cattura: un picco isolato di oltre 2.000 pacchetti al secondo intorno al secondo 36, in corrispondenza della scansione.

4.1.3 Impronta dei pacchetti di scansione

Tutti i 1.026 SYN hanno gli stessi valori nei campi IP e TCP (Tabella 1). Un'uniformità così totale su oltre mille pacchetti indica che il traffico è prodotto da un unico strumento automatico e non da connessioni di applicazioni reali.

Tabella 1: Caratteristiche costanti dei pacchetti SYN della scansione.

Campo	**Valore**
TTL	64
Window size	64240
Opzioni TCP	MSS=1460, SACK_PERM, Timestamps, NOP, Window Scale=7 (128)
Dimensione del pacchetto	74 byte
Porta di origine	diversa a ogni pacchetto
Porta di destinazione	da 1 a 1024, in ordine non sequenziale

4.1.4 Porte aperte

Il filtro `tcp.flags.syn==1 && tcp.flags.ack==1` isola le risposte SYN-ACK con cui il bersaglio conferma una porta aperta (Fig. 4). Escludendo la risposta al primo tentativo isolato sulla porta 80, le porte aperte sono **12** (Tabella 2).

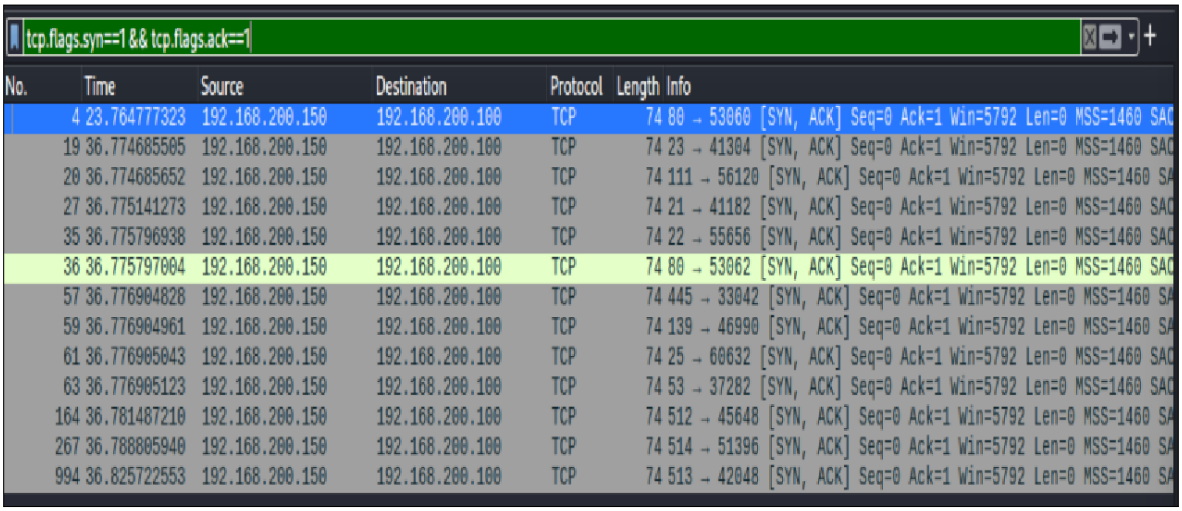


Figura 4: Risposte SYN-ACK del bersaglio: le porte effettivamente aperte.

Tabella 2: Porte aperte individuate su 192.168.200.150.

Porta	**Servizio**	**Porta**	**Servizio**
21	FTP	111	rpcbind
22	SSH	139	NetBIOS-SSN
23	Telnet	445	Microsoft-DS (SMB)
25	SMTP	512	exec (rexec)
53	DNS	513	login (rlogin)
80	HTTP	514	shell (rsh)

4.1.5 Identificazione del bersaglio

Più elementi indipendenti permettono di riconoscere il sistema bersaglio senza accedervi (*OS fingerprinting* passivo):

- il pacchetto broadcast annuncia l'hostname **METASPLOITABLE**;
- il TTL delle risposte è 64, valore iniziale tipico dei sistemi Linux e Unix (Windows parte da 128);
- sono aperti i servizi *r-services* Unix (porte 512, 513 e 514), che Windows non implementa;
- è aperta la porta 111 (rpcbind, il portmapper Unix), mentre la 135 (MSRPC, l'equivalente Windows) risulta chiusa pur essendo stata sondata.

L'insieme è coerente con **Metasploitable2**, la macchina virtuale Linux (basata su Ubuntu 8.04) volutamente vulnerabile usata per l'addestramento.

4.2 Ipotesi sul vettore di attacco

4.2.1 Tipo di scansione

Per ognuna delle 13 porte che hanno risposto con SYN-ACK (le 12 aperte più il primo tentativo sulla porta 80) la sequenza di pacchetti è sempre la stessa:

```
SYN (client)  ->  SYN,ACK (bersaglio)  ->  ACK (client)  ->  RST,ACK (client)
```

In tutti i casi il client completa l'handshake con un ACK esplicito e poi chiude subito la connessione con un RST,ACK. Questo comportamento, insieme alle opzioni TCP complete dei SYN (MSS, SACK, Timestamps, Window Scale, window di 64240, vedi Tabella 1), **non è compatibile con una SYN scan** (`-sS`): quella scansione non completa l'handshake e usa pacchetti costruiti da Nmap con un proprio insieme ridotto di opzioni.

È invece pienamente compatibile con una **TCP Connect scan** (`-sT`). In questa modalità Nmap non costruisce i pacchetti a mano, ma chiede al sistema operativo di aprire una connessione vera con la chiamata `connect()`. Ogni tentativo passa quindi dallo stack TCP/IP del kernel: da qui le opzioni TCP *native* di Linux e l'handshake completato sulle porte aperte, seguito dalla chiusura immediata. `-sT` è anche la modalità che Nmap usa in automatico quando viene eseguito senza privilegi di amministratore.

4.2.2 Ricostruzione del comando

Sulla base degli indicatori raccolti, il traffico è compatibile con il comando:

```
nmap -sT -p 1-1024 <bersaglio>
```

eseguito con una temporizzazione molto aggressiva, ad esempio `-T4`/`-T5` o un `--min-rate` esplicito, viste le velocità superiori a 9.500 pacchetti al secondo. La sequenza temporale della cattura è coerente con questa ricostruzione:

1. un primo contatto isolato sulle porte 80 e 443, verosimilmente una verifica manuale del servizio web;
2. una risoluzione ARP dell'indirizzo del bersaglio, tipica della fase di scoperta degli host di Nmap su una rete Ethernet locale;
3. la scansione vera e propria, con le caratteristiche descritte nel §4.1.

Si tratta quindi, con ogni probabilità, della **fase di ricognizione** che precede lo sfruttamento di uno dei servizi esposti. Metasploitable2 è nota per avere vulnerabilità critiche proprio su alcuni di questi servizi, tra cui vsftpd (porta 21), Samba (porte 139 e 445) e i servizi r-* (porte 512–514).

4.3 Verifica sperimentale in laboratorio

Per verificare l'ipotesi, la scansione è stata riprodotta nel laboratorio isolato descritto nel §3, confrontando due modalità di Nmap con la cattura originale.

4.3.1 SYN scan (-sS)

La prima prova è stata eseguita con:

```
sudo nmap -sS -p 1-1024 -T4 -n -Pn -v 192.168.200.150
```

La scansione trova le stesse 12 porte aperte, ma il traffico è diverso dall'originale (Fig. 5): i SYN misurano 58 byte, hanno una window di **1024** e la sola opzione MSS, senza SACK, Timestamps né Window Scale. Inoltre sulle porte aperte non c'è l'ACK di completamento dell'handshake: dopo il SYN-ACK il client risponde solo con un RST.

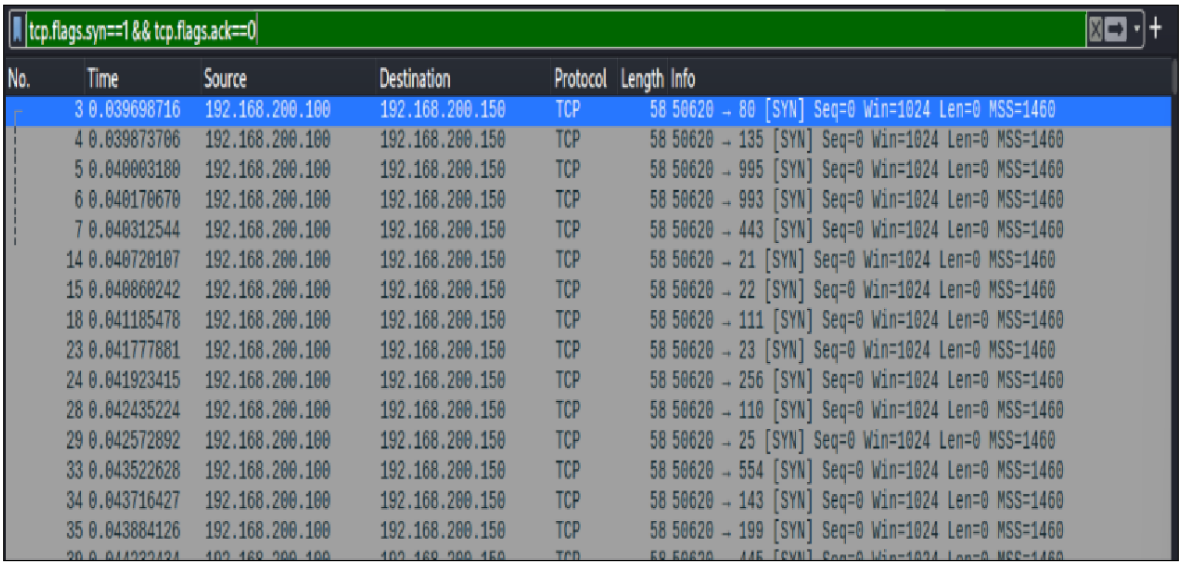


Figura 5: SYN scan riprodotta in laboratorio: pacchetti da 58 byte con window 1024 e sola opzione MSS, diversi da quelli della cattura originale.

4.3.2 TCP Connect scan (-sT)

La seconda prova è stata eseguita con:

```
sudo nmap -sT -p 1-1024 -T4 -n -Pn -v 192.168.200.150
```

Nmap conferma la modalità (*Initiating Connect Scan*) e trova le **stesse 12 porte aperte** in 1,28 secondi (Fig. 6).

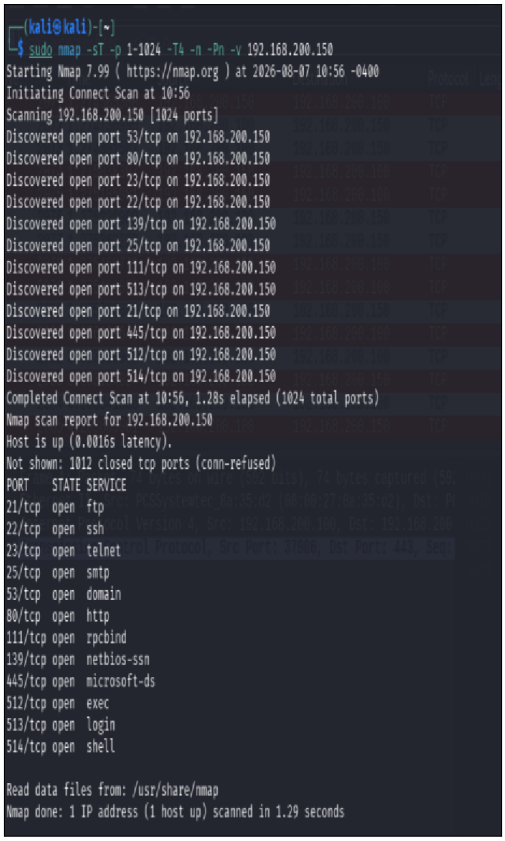


Figura 6: Output di nmap -sT in laboratorio: Connect Scan, 12 porte aperte, scansione completata in 1,28 secondi.

Nella cattura i SYN tornano ad avere 74 byte, window 64240 e le opzioni native del kernel, MSS, SACK_PERM e Timestamps (Fig. 7); sulle porte aperte la sequenza SYN, SYN-ACK, ACK viene completata come nell'originale (Fig. 8). Anche il volume è quasi identico: 2.083 pacchetti tra i due host contro i 2.078 della cattura originale (Fig. 9).

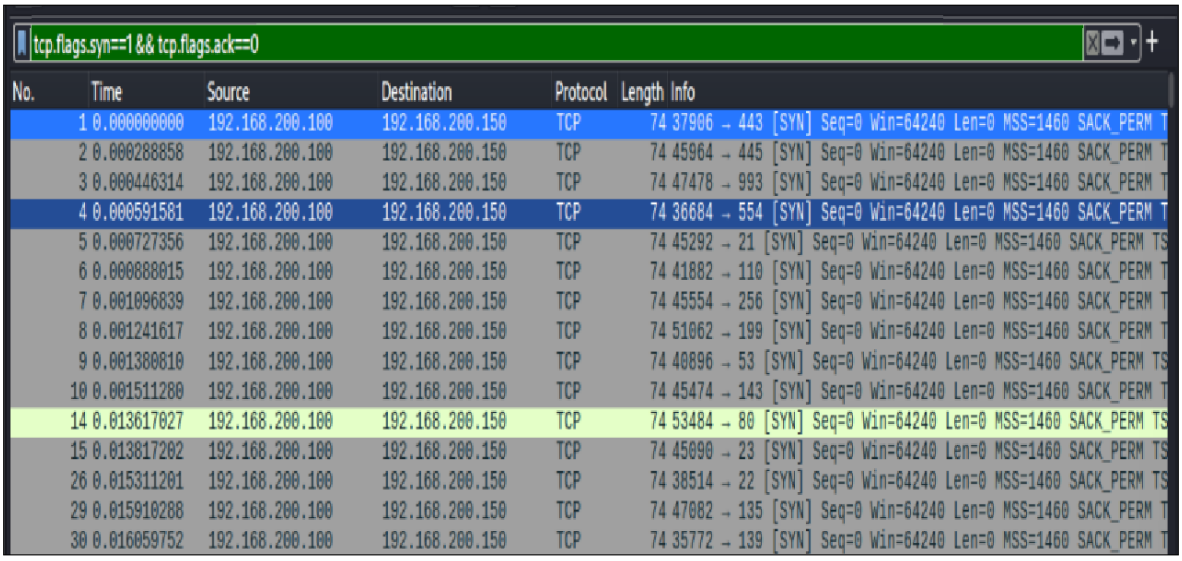


Figura 7: Connect scan in laboratorio: SYN da 74 byte con window 64240 e opzioni MSS, SACK_PERM e Timestamps, come nell'originale.

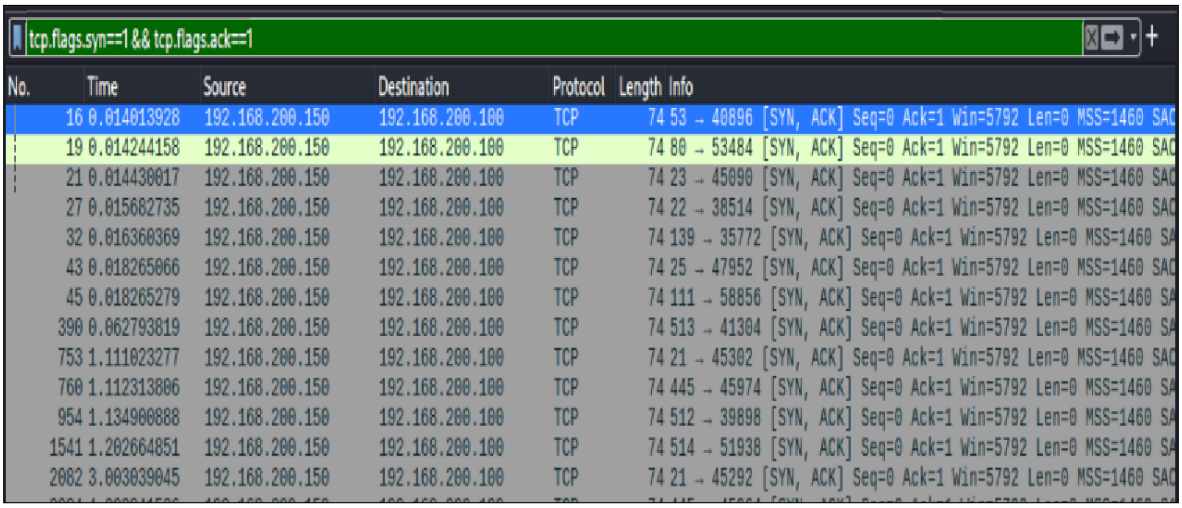


Figura 8: Connect scan in laboratorio: le risposte SYN-ACK corrispondono alle stesse 12 porte aperte.

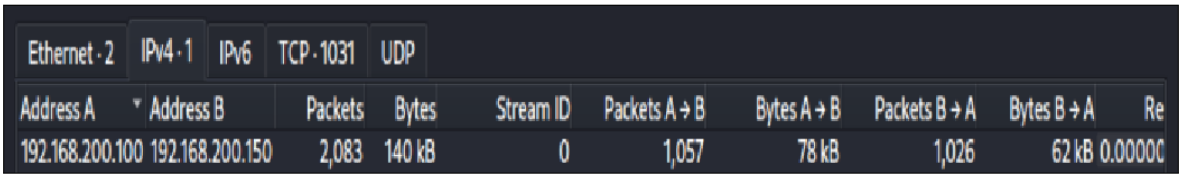


Figura 9: Connect scan in laboratorio: 2.083 pacchetti tra i due host, un volume quasi identico all'originale.

4.3.3 Confronto dei risultati

Tabella 3: Confronto tra la cattura originale e le due scansioni riprodotte.

Caratteristica	**Cattura originale**	**Laboratorio -sS**	**Laboratorio -sT**
Dimensione dei SYN	74 byte	58 byte	74 byte
Window size	64240	1024	64240
Opzioni TCP	MSS, SACK, Timestamps, Window Scale	solo MSS	MSS, SACK, Timestamps
ACK dopo il SYN-ACK	sì	no	sì
Porte aperte trovate	12	12	12
Pacchetti tra i due host	2.078	2.060	2.083
Durata della scansione	circa 105 ms	circa 0,26 s (dalla cattura)	1,28 s (da Nmap)

Su tutte le caratteristiche che dipendono dal modo in cui i pacchetti vengono costruiti, la Connect scan coincide con l'originale e la SYN scan no. L'unica differenza è la durata: 1,28 secondi in laboratorio contro circa 105 millisecondi nella cattura originale (Fig. 10). Una Connect scan è strutturalmente più lenta di una SYN scan, perché ogni tentativo apre una connessione vera attraverso il kernel, e infatti nello stesso laboratorio il traffico della `-sS` si esaurisce in circa 0,26 secondi. La maggiore velocità dell'originale può dipendere dall'hardware, dalla virtualizzazione o da opzioni di temporizzazione più spinte, ma con i dati disponibili non è possibile stabilirlo. Questa differenza non riguarda comunque il tipo di scansione, che risulta confermato.

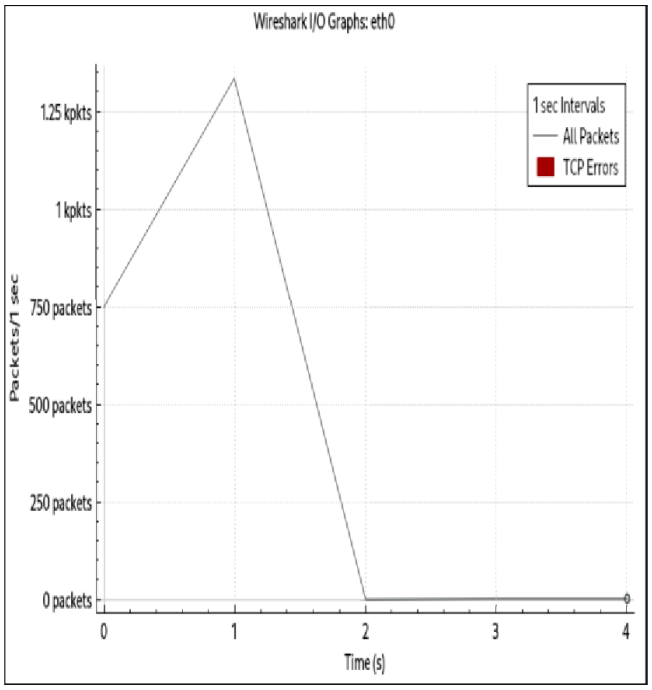


Figura 10: Grafico I/O della Connect scan in laboratorio: stessa firma dell'originale, ma con il picco distribuito su un tempo più lungo.

4.4 Contromisure

4.4.1 Ridurre l'impatto dell'attacco osservato

- Rilevare le scansioni in tempo reale con un IDS/IPS di rete (ad esempio Suricata o Snort), con regole a soglia del tipo *N porte diverse contattate dallo stesso IP in X secondi*.
- Limitare con firewall o ACL l'accesso all'host esposto ai soli indirizzi autorizzati, isolandolo dal resto della rete.
- Applicare un limite alle nuove connessioni in ingresso (ad esempio con il modulo `recent` di iptables o con fail2ban) per rallentare le scansioni aggressive.

4.4.2 Prevenire attacchi simili

- Disattivare i servizi non necessari e intrinsecamente insicuri (Telnet, FTP, servizi r-* sulle porte 512–514), sostituendoli con alternative cifrate come SSH e SFTP.
- Segmentare la rete, separando gli host con servizi critici dal resto dell'infrastruttura.
- Mantenere aggiornati i servizi esposti e controllare periodicamente quali porte sono realmente in ascolto, per scoprire servizi dimenticati.
- Valutare honeypot o strumenti di *deception*, che danno un allarme precoce in caso di ricognizione sulla rete.

5 Conclusioni

Partendo da un indicatore semplice, molte connessioni verso porte diverse in pochissimo tempo, l'analisi ha permesso di identificare lo strumento (Nmap), la tecnica (TCP Connect scan, `-sT`) e un comando compatibile, usando indizi su più livelli: la temporizzazione della scansione, l'impronta delle opzioni TCP e soprattutto il comportamento dell'handshake sulle porte aperte. Anche il bersaglio è stato identificato incrociando indicatori indipendenti (hostname annunciato, TTL, servizi tipici di Unix, assenza di servizi Windows).

La verifica in laboratorio è stata decisiva: il confronto tra le due modalità di Nmap ha mostrato in modo misurabile quale delle due produce il traffico osservato. Un'attribuzione non verificata resta un'ipotesi; riprodurre il traffico in un ambiente controllato la trasforma in una conclusione.

Dal punto di vista difensivo, una scansione di porte è spesso la prima fase osservabile di un attacco più ampio. Riconoscerla in tempo dà la possibilità di intervenire prima della fase di sfruttamento, tanto più quando, come qui, i servizi scoperti sono noti per avere vulnerabilità critiche. Come sviluppo, gli indicatori individuati possono diventare regole automatiche per un IDS e il metodo di verifica può essere esteso ad altre tecniche, come le scansioni UDP (`-sU`) o quelle con frammentazione e indirizzi esca, per costruire un catalogo di impronte di riferimento.